GUIDE DE DÉPLOIEMENT

Entra ID P1

Minimum Viable de Conformité (MVC)

PME suisse 5 à 25 personnes, Microsoft 365 Business Premium

Licence :	Microsoft 365 Business Premium (Entra ID P1 inclus)
Tenant :	[tenant].onmicrosoft.com (à remplacer)
Client :	[Nom du client] (à remplacer)
Durée :	2 à 3 heures (déploiement + tests)
Prérequis :	MVC Purview déployé (ou au minimum Audit actif)
Version :	3.4, novembre 2026

Table des matières

Pour mettre à jour la table : clic droit, Mettre à jour les champs (ou Ctrl+A puis F9).

ATTENTION remplacez `[tenant]` et `[Nom du client]` par les informations réelles du client avant toute utilisation.

Préface

INFO ce guide est un guide nLPD (nouvelle Loi fédérale sur la Protection des Données, Suisse, RS 235.1). Délai de notification d'une violation : « dès que possible », pas de délai fixe de 72 heures comme dans le RGPD européen. Autorité compétente : PFPDT, pas la CNIL.

Ce guide déploie la couche **identité et accès** du bundle MVC nLPD. Il s'inscrit dans un déploiement en 3 sessions : Session 1 MVC Purview (4 à 6 h), Session 2 MVC Entra ID P1 (2 à 3 h, ce guide), Session 3 MVC Intune + Defender (3 à 5 h). Total : 9 à 14 heures, client autonome à la fin. Il est conçu pour être déployé avant ou en parallèle du MVC Intune + Defender.

La nLPD art. 8 exige des mesures techniques de protection adaptées au risque. Le contrôle des identités est la première de ces mesures : un mot de passe volé contourne tous les autres contrôles.

Pilier	Ce que ça apporte
Deux comptes break-glass	Accès de secours exclu de toutes les politiques CA : évite le verrouillage total du tenant
Emplacements nommés	Définit la zone géographique légitime pour les règles de filtrage `[nLPD art. 8]`
MFA obligatoire (CA-01)	Première barrière contre la compromission de compte `[nLPD art. 8]`
Blocage auth. héritée (CA-02)	Ferme le contournement du MFA via IMAP, POP3, SMTP, EAS `[nLPD art. 8]`
Filtrage géographique (CA-03)	Bloque les connexions depuis des pays non autorisés `[nLPD art. 8]`
Token Protection (CA-04)	Bloque le vol de session post-MFA (attaques AiTM) `[nLPD art. 8]`
Session limitée (CA-05)	Restreint les sessions sur appareils non gérés `[nLPD art. 8]`
Hors horaires (CA-06)	Signale ou bloque les connexions hors heures ouvrables `[nLPD art. 8]`
Appareil conforme (CA-08)	Exige un appareil conforme Intune, en mode Rapport puis Application `[nLPD art. 8]`
SSPR	Réinitialisation autonome et auditée des mots de passe `[nLPD art. 8]`

INFO ce guide est strictement limité à Entra ID P1, inclus dans Microsoft 365 Business Premium. Les fonctionnalités Entra ID P2 (Identity Protection, PIM, Access Reviews) sont hors périmètre MVC : elles exigent un add-on de licence supplémentaire (Defender Suite).

INFO **vocabulaire du portail.** Dans le formulaire d'une stratégie, l'état « Application » de ce guide correspond au réglage **Activé** de « Activer une stratégie » (les autres choix sont « Rapport uniquement » et « Désactivé »). Les contrôles se règlent sous « Contrôles d'accès » : **Octroyer** (accorder ou bloquer) et **Session**.

INFO **dates et statuts vérifiés le 6 novembre 2026** sur la documentation et le centre de messages Microsoft. Les calendriers Microsoft évoluent : revérifiez les dates marquées « 2026 » avant chaque déploiement.

INFO il n'existe pas de politique CA-07 dans le MVC. La numérotation CA-01 à CA-06 puis CA-08 est conservée pour rester identique dans tous les guides du bundle (le nom `CA-08` est référencé dans le guide Intune + Defender).

Partie 0 : Prérequis

0.1 Portail et rôles

N°	Étape	Action
1	Navigateur	Microsoft Edge ou Chrome. Évitez Firefox pour les portails admin.
2	URL	https://entra.microsoft.com
3	Connexion	Compte admin M365 (Administrateur général ou Administrateur de la sécurité).
4	Rôles requis	Administrateur de la sécurité → politiques CA, méthodes d'authentification. Administrateur de l'authentification → SSPR, méthodes, TAP. Administrateur de stratégie d'authentification → Authentication Strength.

ATTENTION après ajout d'un rôle, déconnectez-vous et reconnectez-vous. Les rôles ne prennent pas effet dans la session en cours.

0.2 Deux comptes break-glass

IMPORTANT créez les deux comptes break-glass AVANT d'activer toute politique CA. Sans eux, une mauvaise configuration peut vous bloquer définitivement hors du tenant, sans recours possible. Microsoft recommande deux comptes avec des méthodes d'authentification différentes.

N°	Étape	Action
1	Compte BG-1	entra.microsoft.com → Utilisateurs → + Nouvel(le) utilisateur(-trice). Nom : `bga1@[tenant].onmicrosoft.com` (en production, utilisez des noms neutres de type humain, par exemple `prenom.nom@[tenant].onmicrosoft.com`, pour masquer la fonction du compte). Domaine : toujours `@[tenant].onmicrosoft.com` (cloud-only). Méthode MFA : FIDO2 (clé physique stockée en coffre). Pas de licence assignée. Mot de passe de 25 caractères ou plus.
2	Compte BG-2	Même principe, nom neutre différent. Méthode MFA : Authenticator sur appareil dédié hors réseau. Mot de passe différent de BG-1.
3	Groupe break-glass	entra.microsoft.com → Groupes → + Nouveau groupe → Sécurité → Nom : `GRP-CA-BreakGlass` → Membres : bga1 + bga2 → Créer.
4	Enregistrement MFA	Enregistrer au moins une méthode MFA forte (FIDO2 ou CBA) sur chaque compte break-glass. Connexion test bga1 dans une fenêtre privée → accès au portail Entra ID.

ATTENTION **MFA des portails admin.** Microsoft impose le MFA au niveau des portails admin indépendamment des politiques CA : portails Azure, Entra et Intune depuis octobre 2024 ; centre d'administration Microsoft 365 depuis février 2025 (déploiement progressif) ; Azure CLI, Azure PowerShell, API REST, SDK et outils d'infrastructure as code depuis le 1er octobre 2025 (opérations de création, modification et suppression). Le report possible jusqu'au 1er juillet 2026 est expiré : l'application est désormais effective sur tous les tenants. Les comptes break-glass restent exclus de toutes les CA, mais une invite MFA portail apparaîtra. C'est pourquoi FIDO2 ou CBA doit être enregistré : sans méthode MFA, le compte break-glass ne peut plus accéder aux portails.

ATTENTION **test trimestriel.** Testez les deux comptes chaque trimestre. Changez les mots de passe tous les 90 jours. Documentez dans le registre de sécurité.

0.3 Désactiver Security Defaults

ATTENTION Security Defaults et l'accès conditionnel ne peuvent pas coexister. Si Security Defaults est activé, désactivez-le avant de créer des politiques CA. Les deux systèmes en conflit provoquent des comportements imprévisibles.

N°	Étape	Action
1	Accès	entra.microsoft.com → Vue d'ensemble → Propriétés → descendre jusqu'à la section « Paramètres de sécurité par défaut ».
2	Désactiver	Toggle : Désactiver. Motif : Utilisation de l'accès conditionnel (P1).
3	Enregistrer	Cliquez Enregistrer.

INFO si des politiques d'accès conditionnel existent déjà, le portail n'affiche pas l'interrupteur et indique : « Votre organisation utilise actuellement des stratégies d'accès conditionnel qui vous empêchent d'activer les paramètres de sécurité par défaut ». Security Defaults est alors déjà désactivé, rien à faire.

INFO si Security Defaults était actif, les utilisateurs déjà enregistrés en MFA gardent leur enregistrement. Procédez directement à la configuration des politiques CA.

Partie 1 : Méthodes d'authentification

1.1 Activer les méthodes recommandées

Chemin : entra.microsoft.com → Protection → Méthodes d'authentification → Stratégies

N°	Étape	Action
1	Microsoft Authenticator	Cliquer → Activer → Tous les utilisateurs → Enregistrer. Méthode privilégiée : passkeys FIDO2 disponibles dans l'app depuis 2026.
2	Clé d'accès (FIDO2)	Cliquer → Activer → Tous les utilisateurs → Autoriser les passkeys synchronisés (Authenticator app) + liés à l'appareil (clés physiques YubiKey). Enregistrer.
3	SMS	Activer → Tous les utilisateurs → Enregistrer. Secours si l'application est inaccessible.
4	Appel vocal	Optionnel. Utile pour les utilisateurs sans smartphone compatible.

INFO **migration des stratégies héritées.** Depuis le 30 septembre 2025, les anciennes stratégies MFA et SSPR sont déconnectées et les paramètres sont gérés par ces stratégies unifiées. La page affiche un bandeau « État de la migration » : terminez la migration (lien « changer ») si elle est « En cours ». Le portail peut aussi annoncer l'activation automatique des clés d'accès pour les utilisateurs qui utilisent le SMS ou l'appel vocal.

ATTENTION **MFA per-user legacy.** Vérifiez qu'aucun utilisateur n'est en statut « Appliqué » (Enforced) dans l'ancienne interface MFA : admin.microsoft.com → Utilisateurs actifs → Authentification multifacteurs. Tous doivent être en « Désactivé ». Les deux systèmes en conflit provoquent des blocages inexpliqués.

1.2 Passe d'accès temporaire (TAP)

Chemin : Protection → Méthodes d'authentification → Stratégies → Passe d'accès temporaire (la page de réglages s'intitule « Paramètres Droit d'accès temporaire »)

N°	Étape	Action
1	Activer	Onglet « Activer et cibler » → Activer : interrupteur sur Activé. Cible : Tous les utilisateurs.
2	Durée	Onglet « Configurer » → Modifier. Durée de vie minimale : 1 heure. Durée de vie maximale : 8 heures. Durée de vie par défaut : 1 heure (valeurs par défaut du portail).
3	Usage unique	Onglet « Configurer » → Une seule fois : Oui (recommandé pour l'onboarding). La valeur par défaut est Non. Longueur : 8 caractères (par défaut).
4	Enregistrer	Cliquer Enregistrer.

INFO le TAP est le moyen recommandé pour enregistrer le premier facteur MFA (passkey ou FIDO2) lors de l'onboarding. Émission : entra.microsoft.com → Utilisateurs → [utilisateur] → Méthodes d'authentification → + Ajouter une méthode d'authentification → Passe d'accès temporaire (chemin à confirmer sur le portail).

1.3 Points forts d'authentification (Authentication Strength)

Chemin : Protection → Méthodes d'authentification → Points forts d'authentification (également accessible par Accès conditionnel → Points forts d'authentification)

N°	Étape	Action
1	3 niveaux intégrés	**Authentification multifacteur (niveau 1)** : combinaisons de méthodes qui répondent à une authentification forte, par exemple mot de passe + SMS. Utilisée par CA-01. **Authentification multifacteur sans mot de passe (niveau 2)** : méthodes sans mot de passe, comme Microsoft Authenticator. **MFA anti-hameçonnage (niveau 3)** : méthodes sans mot de passe résistantes au hameçonnage, comme la clé de sécurité FIDO2.
2	Vérification	Confirmer que les 3 niveaux intégrés sont visibles. Aucune création nécessaire sauf besoin spécifique.

1.4 Campagne d'inscription

Chemin : Protection → Méthodes d'authentification → Campagne d'inscription

N°	Étape	Action
1	État	Valeur par défaut observée : « Managé par Microsoft » (Microsoft ajuste les paramètres de la campagne). Les champs Méthode d'authentification, « Nombre de jours autorisés pour la répétition » et « Nombre limité de répétitions » sont grisés dans cet état.
2	Périmètre	Inclure : Tous les utilisateurs. Exclure → Sélectionner un groupe → `GRP-CA-BreakGlass`.
3	Enregistrer	Cliquer Enregistrer.

INFO la campagne d'inscription invite (rappel après connexion) les utilisateurs à configurer Microsoft Authenticator ou une clé d'accès (FIDO2). Elle ne force pas l'enregistrement : c'est CA-01 qui l'impose. Les utilisateurs doivent avoir la méthode activée dans les stratégies pour être éligibles au rappel.

CONSEIL envoyez un email aux utilisateurs AVANT l'activation de CA-01 avec le lien d'enregistrement : https://aka.ms/mfasetup. Sans préavis, ils seront bloqués à leur prochaine connexion.

ATTENTION **CA pendant l'enregistrement.** Depuis juillet 2026 (déploiement annoncé du 6 au 13 juillet 2026), les politiques CA ciblant l'action utilisateur « Inscrire des informations de sécurité » s'appliquent aussi pendant le provisionnement de Windows Hello Entreprise et de macOS Platform SSO. Le MVC ne crée pas de politique sur cette action : aucun impact. Si le client en ajoute une, testez-la en mode Rapport avant application, sous peine de bloquer l'enregistrement des nouveaux collaborateurs.

Partie 2 : Emplacements nommés

nLPD art. 8 al. 1 : contextualisation géographique des accès. La nLPD art. 8 exige des mesures techniques adaptées au risque. Définir les zones géographiques légitimes d'accès permet de bloquer les connexions depuis des pays à risque et de conditionner le MFA selon la localisation. Les emplacements nommés sont la base de la politique CA-03.

ATTENTION créez les emplacements nommés AVANT les politiques CA qui les référencent. Un emplacement inexistant invalide la politique CA.

2.1 Pays autorisés

Chemin : entra.microsoft.com → Protection → Accès conditionnel → Emplacements nommés → + Emplacement des pays

N°	Étape	Action
1	Nom	`Pays-Autorises-[Client]`
2	Méthode	Méthode de recherche de pays : « Déterminer l'emplacement avec l'adresse IP (IPv4 et IPv6) » (valeur par défaut).
3	Pays	Cocher : CH (Suisse). Ajouter selon les besoins réels du client : DE, FR, IT, AT, LI. Documenter chaque pays ajouté avec la justification métier.
4	Pays inconnus	Case « Inclure des pays/régions inconnus » : laisser DÉCOCHÉE. Les pays non listés seront bloqués par CA-03.
5	Créer	Cliquer Créer.

2.2 Bureau (IP fixe)

Chemin : Emplacements nommés → menu « … » de la barre d'outils → + Emplacement des plages d'adresses IP

N°	Étape	Action
1	Nom	`Bureau-[Client]`
2	Marqué approuvé	Cocher : Marquer comme emplacement approuvé.
3	Plage IP	Cliquer sur le bouton « + », puis saisir l'IP fixe du bureau en CIDR (exemple : 203.0.113.10/32). Demander à l'opérateur si nécessaire.
4	Créer	Cliquer Créer.

ATTENTION si le client n'a pas d'IP fixe, sautez cet emplacement. CA-01 s'appliquera avec MFA depuis le bureau, sans exception.

Partie 3 : CA-01, MFA pour tous les utilisateurs

nLPD art. 8 al. 1 : première mesure de protection contre la compromission de compte. La nLPD art. 8 exige des mesures techniques de protection proportionnelles au risque. Le MFA est la mesure la plus efficace contre la compromission de compte par credential stuffing : attaque automatisée testant des millions de mots de passe volés. Sans MFA, un mot de passe volé suffit à contourner toute la protection Purview.

IMPORTANT exigez le MFA sur le compte admin AVANT d'activer CA-01 en mode Application. Sans cela, CA-01 peut déclencher une boucle d'authentification sur le compte admin et bloquer l'accès au portail.

N°	Étape	Action
C1	Mode rapport	Activer CA-01 en mode Rapport uniquement pendant 7 jours. Vérifier dans les journaux (Surveillance → Journaux de connexion → colonne « Résultat de la politique CA ») que la politique s'applique aux bons utilisateurs.
1	Nom	`CA-01-MFA-Tous-Utilisateurs`
2	Utilisateurs → Inclure	Tous les utilisateurs.
3	Utilisateurs → Exclure	`GRP-CA-BreakGlass`.
4	Ressources cibles	Toutes les ressources (anciennement « Toutes les applications cloud »).
5	Contrôles d'accès → Octroyer	Accorder l'accès → cocher « Exiger la force de l'authentification » → choisir « Authentification multifacteur » → Sélectionner. Ne pas cocher en plus « Exiger une authentification multifacteur » : le portail refuse de combiner les deux.
6	Activer une stratégie	Rapport uniquement → 7 jours → puis Activé.
7	Créer	Cliquer Créer.

CONSEIL **test.** Connexion avec un compte utilisateur standard en navigation privée → l'invite MFA apparaît. Connexion bga1 → pas d'invite MFA de la politique CA (compte exclu).

Partie 4 : CA-02, Blocage de l'authentification héritée

nLPD art. 8 al. 1 : fermeture du vecteur de contournement du MFA. Les protocoles IMAP, POP3, SMTP AUTH et Exchange ActiveSync basique ne supportent pas l'accès conditionnel : ils contournent donc le MFA. Un compte avec CA-01 actif reste entièrement vulnérable si l'authentification héritée n'est pas bloquée.

N°	Étape	Action
C1	Sûreté	Application directe : les applications M365 modernes (Outlook, Teams, SharePoint, Outlook mobile) utilisent OAuth 2.0 et ne sont pas affectées.
1	Nom	`CA-02-Blocage-Auth-Heritee`
2	Utilisateurs → Inclure	Tous les utilisateurs.
3	Utilisateurs → Exclure	`GRP-CA-BreakGlass`.
4	Ressources cibles	Toutes les ressources (anciennement « Toutes les applications cloud »).
5	Conditions → Applications clientes	Configurer : Oui → cocher, sous « Clients d'authentification hérités » : Clients Exchange ActiveSync + Autres clients (IMAP, POP3, SMTP legacy). Laisser Navigateur et Applications mobiles et clients de bureau décochés.
6	Contrôles d'accès → Octroyer	Bloquer l'accès → Sélectionner.
7	Activer une stratégie	Activé → Créer.

CONSEIL **test.** Tentative de connexion IMAP ou Outlook 2010 avec un compte utilisateur → erreur « Accès bloqué par les politiques d'accès conditionnel ».

Partie 5 : CA-03, Filtrage géographique

nLPD art. 8 al. 1 : réduction de la surface d'attaque géographique. La grande majorité des attaques de credential stuffing provient de pays tiers. Bloquer les connexions depuis des pays non autorisés réduit significativement l'exposition, sans impact sur les utilisateurs légitimes connectés depuis la Suisse et les pays voisins configurés.

N°	Étape	Action
C1	Mode rapport	14 jours en mode Rapport. Vérifier que personne de légitime ne serait bloqué, notamment les collaborateurs en déplacement.
1	Nom	`CA-03-Blocage-Pays-Non-Autorises`
2	Utilisateurs → Inclure	Tous les utilisateurs.
3	Utilisateurs → Exclure	`GRP-CA-BreakGlass`.
4	Ressources cibles	Toutes les ressources (anciennement « Toutes les applications cloud »).
5	Réseau (ou Conditions → Emplacements) → Configurer : Oui → Inclure	N'importe quel réseau ou emplacement.
6	Réseau → Exclure	Réseaux et emplacements sélectionnés → `Pays-Autorises-[Client]`.
7	Contrôles d'accès → Octroyer	Bloquer l'accès → Sélectionner.

N°	Étape	Action
8	Activer une stratégie	Rapport uniquement → 14 jours → puis Activé.
9	Créer	Cliquer Créer.

ATTENTION **avant d'activer.** Si des collaborateurs se connectent régulièrement depuis des pays non listés (déplacements professionnels), ajoutez ces pays à `Pays-Autorises-[Client]` avant de passer en Application.

Partie 6 : CA-04, Token Protection

nLPD art. 8 al. 1 : protection contre le vol de session post-MFA. Les attaques AiTM contournent le MFA en interceptant le cookie de session. Token Protection lie cryptographiquement le token au TPM de l'appareil, rendant un cookie volé inutilisable depuis un autre appareil. Prérequis : WHfB doit être actif sur les postes (configuré via MVC Intune) pour que la liaison TPM soit opérationnelle. Pour le contexte de l'attaque : annexe AiTM / Cookie Hijacking.

ATTENTION **conditions réelles pour une PME cloud-only (périmètre MVC).**

Token Protection supporte les applications natives (Outlook, Teams, OneDrive, Word, Excel, PowerPoint, OneNote, Edge pour la connexion au profil uniquement, etc.) sur Windows, avec Exchange Online, SharePoint Online et Teams comme ressources. Les applications web dans un navigateur ne sont pas supportées. Côté Apple (macOS 14+, iOS/iPadOS 16+), la documentation Microsoft est incohérente sur le statut (disponibilité générale dans un tableau, « préversion » dans une autre section) et exige un appareil géré par MDM avec le plug-in Microsoft Enterprise SSO : ne pas activer en Application sans test. Les applications natives Mail et Calendrier d'Apple ne supportent pas Token Protection : les utilisateurs seraient bloqués.

Types d'enregistrement Windows non supportés (accès bloqué, code `signInSessionStatusCode` 1003 dans les journaux) : appareils déployés par inscription en masse (bulk enrollment), Windows Autopilot en mode self-deploying, Cloud PC Windows 365 joints à Entra, hôtes de session Azure Virtual Desktop joints à Entra. Excluez-les avec un filtre d'appareil.

En environnement hybride (Hybrid Entra Join + AD on-prem), le Cloud Kerberos Trust est requis en plus : hors périmètre MVC, voir l'annexe AiTM §6.

Dans une PME suisse, la majorité des accès passe par navigateur ou appareils Apple : Token Protection ne protège pas ces vecteurs.

N°	Étape	Action
C1	Prérequis stricts	WHfB activé via MVC Intune (intune.microsoft.com → Appareils → Inscription → Windows → Windows Hello Entreprise, politique à l'échelle du tenant). En environnement cloud-only, c'est la seule étape requise : pas de Cloud Kerberos Trust, pas d'AzureADKerberos. Le Cloud Kerberos Trust n'est requis qu'en hybride (Hybrid Entra Join + AD on-prem), hors périmètre MVC. Parc Windows uniquement, TPM 2.0 actif, aucun accès navigateur ni appareil Apple dans le périmètre.
C2	Déployer en 2 temps	Phase 1 (ce guide) : créer CA-04 en Rapport uniquement, groupe pilote Direction + admins. Phase 2 (après MVC Intune) : activer en Application uniquement après que WHfB est déployé et validé sur les postes (`dsregcmd /status` → `NgcSet : YES` + `TpmProtected : YES`) et que 100 % des appareils dans le périmètre sont Windows avec TPM 2.0.
1	Nom	`CA-04-Token-Protection-Exchange-SharePoint`
2	Utilisateurs → Inclure	Groupe pilote (Direction + admins). Ne pas inclure tous les utilisateurs avant validation terrain.

N°	Étape	Action
3	Utilisateurs → Exclure	`GRP-CA-BreakGlass`.
4	Ressources cibles	Office 365 Exchange Online + Office 365 SharePoint Online uniquement (pas « Toutes les ressources »).
5	Session	Contrôles d'accès → Session → cocher : Exiger une protection par jeton pour les sessions de connexion.
6	Activer une stratégie	Rapport uniquement → Créer. Passer en Application après MVC Intune et confirmation WHfB opérationnel (`dsregcmd /status` → `NgcSet : YES` + `TpmProtected : YES` sur tous les postes dans le périmètre).

CONSEIL **test en Rapport.** Journaux de connexion → filtrer sur CA-04 → colonne « Résultat CA ». Si des navigateurs ou appareils Apple apparaissent : ajustez le périmètre avant tout passage en Application.

Partie 7 : CA-05, Session limitée sur appareils non gérés

nLPD art. 8 al. 1 : contrôle des accès depuis les appareils personnels. Un appareil personnel non géré peut être compromis, partagé ou perdu sans que l'organisation en soit informée. Limiter les sessions SharePoint et OneDrive sur ces appareils (lecture seule, pas de téléchargement) réduit le risque d'exfiltration de données personnelles.

N°	Étape	Action
C1	Prérequis SharePoint	Centre admin SharePoint → Stratégies → Partage → Accès depuis des appareils non gérés → Autoriser un accès limité au web uniquement. Ce paramètre doit être actif pour que CA-05 soit efficace.
1	Nom	`CA-05-Session-Limitee-Appareils-Non-Geres`
2	Utilisateurs	Inclure : Tous les utilisateurs. Exclure : `GRP-CA-BreakGlass`.
3	Ressources cibles	Office 365 SharePoint Online.
4	Conditions → Filtre pour les appareils	Configurer : Oui → Inclure les appareils filtrés dans la stratégie → Syntaxe de la règle → Modifier : `device.isCompliant -eq False AND device.trustType -ne "ServerAD"`
5	Session	Contrôles d'accès → Session → cocher : Utiliser les restrictions appliquées par l'application.
6	Activer une stratégie	Rapport uniquement → 7 jours → puis Activé.
7	Créer	Cliquer Créer.

CONSEIL **test.** Connexion SharePoint depuis un appareil non géré → accès en lecture seule uniquement, bouton de téléchargement absent.

Partie 8 : CA-06, Blocage des connexions hors horaires

nLPD art. 8 al. 1 : réduction de la surface d'attaque temporelle. Les compromissions post-AiTM ou post-phishing se produisent statistiquement hors heures de bureau. CA-06 signale (mode Rapport) ou bloque les connexions en dehors des heures ouvrables.

ATTENTION la condition temporelle n'est pas disponible dans l'interface graphique Entra ID : elle se configure via Microsoft Graph API (endpoint beta, inclus dans Entra ID P1). Excluez impérativement `GRP-CA-BreakGlass` avant toute activation en Application.

INFO **note nLPD.** Cette politique doit être documentée dans le registre des activités de traitement comme contrôle d'accès système (et non évaluation des employés), communiquée aux utilisateurs dans la politique de sécurité IT, et appliquée de manière proportionnée au risque identifié.

N°	Étape	Action
C1	Plage couverte	Lundi-vendredi de 07h00 à 19h00 CEST (été) ou CET (hiver). Week-end entier bloqué. En UTC : 05h00-17h00 en été (CEST = UTC+2), 06h00-18h00 en hiver (CET = UTC+1). Adapter le corps JSON selon la saison.
C2	Exclusions	`GRP-CA-BreakGlass` impérativement. Exclure aussi les comptes de service si des traitements nocturnes légitimes existent (synchronisation Entra Connect, sauvegardes automatisées).
1	Créer la politique dans Entra ID	entra.microsoft.com → Accès conditionnel → + Nouvelle stratégie. Nom : `CA-06-Blocage-Hors-Horaires`. Utilisateurs : Tous, exclure `GRP-CA-BreakGlass`. Ressources : Toutes les ressources. Octroyer : Bloquer l'accès. Activer une stratégie : Rapport uniquement → Créer.
2	Récupérer l'ID de la politique	Graph Explorer (https://aka.ms/ge) → `GET https://graph.microsoft.com/beta/identity/conditionalAccess/policies` → rechercher `CA-06-Blocage-Hors-Horaires` → copier l'ID (format UUID).
3	PATCH Graph API	`PATCH https://graph.microsoft.com/beta/identity/conditionalAccess/policies/{ID}` avec le corps JSON ci-dessous. La condition exclut les heures ouvrables (lun-ven 05h00-17h00 UTC) : tout le reste (nuits et week-end) est couvert par la politique.

Corps JSON (été, CEST)

```
{
  "conditions": {
    "times": {
      "includeAllTimes": true,
      "excludeDays": {
        "daysOfWeek": ["monday", "tuesday", "wednesday", "thursday", "friday"],
        "timeZone": "UTC",
        "startTime": "05:00:00",
        "endTime": "17:00:00",
        "allDay": false
      }
    }
  }
}
```

CONSEIL **test en Rapport.** Journaux de connexion → filtrer sur CA-06 → colonne « Résultat CA ». Tester une connexion le week-end ou après 19h00 : doit apparaître « Rapport - Échec ». Une connexion en heure ouvrable doit passer normalement.

CONSEIL **test SIEM (UTMStack).** La règle UTMStack M14 (Sign-In Blocked by Conditional Access Policy) détecte les blocages CA via `log.LogonError = BlockedByConditionalAccess`. Corréler avec M3 (Impossible Travel) si le blocage hors horaires coïncide avec un pays inhabituel.

Partie 9 : CA-08, Exiger un appareil conforme

nLPD art. 8 al. 1 : contrôle d'accès par état de sécurité de l'appareil. Un appareil non géré ou non conforme (BitLocker inactif, antivirus absent, version OS obsolète) représente un risque d'exfiltration et de compromission. CA-08 bloque l'accès aux ressources M365 depuis tout appareil ne répondant pas aux critères de conformité Intune.

ATTENTION cette politique est créée ici en mode Rapport uniquement. Elle ne sera activée en Application qu'après le déploiement du MVC Intune + Defender, une fois les politiques de conformité déployées et les appareils en statut « Conforme ».

N°	Étape	Action
C1	Déployer en 2 temps	Phase 1 (ce guide) : créer CA-08 en Rapport uniquement. Phase 2 (après MVC Intune) : passer en Application une fois les appareils conformes dans Intune.
1	Nom	`CA-08-Exiger-Appareil-Conforme`
2	Utilisateurs → Inclure	Tous les utilisateurs.
3	Utilisateurs → Exclure	`GRP-CA-BreakGlass`.
4	Ressources cibles	Toutes les ressources (anciennement « Toutes les applications cloud »).
5	Contrôles d'accès → Octroyer	Accorder l'accès → cocher « Exiger que l'appareil soit marqué comme conforme » → Sélectionner.
6	Activer une stratégie	Rapport uniquement → Créer. Passer en Application après déploiement Intune (voir MVC Intune + Defender, Partie 12).

Partie 10 : SSPR, Réinitialisation du mot de passe

nLPD art. 8 al. 1 : traçabilité des réinitialisations et continuité d'accès. Le SSPR garantit que les réinitialisations de mots de passe sont auditées (journal Entra ID) : traçabilité exigée par la nLPD art. 8. Il réduit aussi les appels helpdesk post-activation MFA, fréquents lors des premiers jours de déploiement.

10.1 Activer SSPR

Chemin : entra.microsoft.com → Protection → Réinitialisation du mot de passe → Propriétés

N°	Étape	Action
1	Statut	Réinitialisation de mot de passe libre-service : Sélectionné (pas Tout, pour exclure les comptes de service).
2	Groupe	+ Sélectionner le groupe → créer `GRP-SSPR-Utilisateurs` → ajouter tous les utilisateurs standards.
3	Enregistrer	Cliquer Enregistrer.

10.2 Méthodes et notifications

Chemin : Réinitialisation du mot de passe → Méthodes d'authentification

N°	Étape	Action
1	Nombre de méthodes requises	2
2	Méthodes	Activer : Notification d'application mobile, Téléphone mobile, E-mail. Ne pas activer « Questions de sécurité » : le portail annonce leur mise hors service en mars 2027.
3	Enregistrer	Cliquer Enregistrer.
4	Notifications	Réinitialisation du mot de passe → Notifications → Notifier les utilisateurs lors de la réinitialisation : Oui. Notifier les admins : Oui.

INFO **environnement hybride.** En environnement AD on-prem avec Entra Connect : Réinitialisation du mot de passe → Intégration locale → Écriture différée : Oui. Sans cette option, le mot de passe est réinitialisé dans le cloud mais pas dans l'AD local.

CONSEIL **test.** https://aka.ms/sspr → réinitialisation avec 2 méthodes → succès → notification reçue → connexion avec le nouveau mot de passe.

ATTENTION **changement SSPR de novembre 2026.** Microsoft arrête de prendre en compte les coordonnées issues de l'annuaire (téléphone mobile, téléphone professionnel, email alternatif) pour vérifier l'identité lors d'une réinitialisation : seules les méthodes explicitement enregistrées par l'utilisateur (https://aka.ms/mfasetup ou mysignins.microsoft.com) sont acceptées. Un utilisateur sans méthode enregistrée ne peut plus réinitialiser son mot de passe seul. L'application, d'abord annoncée pour le 7 septembre 2026, a été repoussée par Microsoft à **début novembre 2026**, avec un déploiement de début à mi-novembre (les messages Microsoft indiquent le 7 ou le 9 novembre selon l'endroit). La campagne d'enregistrement Microsoft a démarré le 5 octobre 2026. Vérifiez la couverture avant et après : entra.microsoft.com → Méthodes d'authentification → Détails d'inscription des utilisateurs.

Partie 11 : Tests et validation

Test	Scénario	Résultat attendu
T1	MFA déclenché (CA-01)	Navigation privée → connexion utilisateur standard → invite MFA → connexion réussie après MFA.
T2	Break-glass non bloqué	Connexion bga1 → invite MFA portail (normale depuis 2025) mais pas de blocage CA-01 (compte exclu). FIDO2 ou Authenticator requis pour passer le MFA portail. Connexion bga2 → idem.
T3	Auth héritée bloquée (CA-02)	Client IMAP ou Outlook 2010 → erreur « Accès bloqué par les politiques d'accès conditionnel ».
T4	Pays bloqué (CA-03)	VPN vers un serveur hors `Pays-Autorises-[Client]` → connexion bloquée.
T5	Session limitée (CA-05)	Appareil non géré → SharePoint → accès en lecture seule, pas de téléchargement.
T6	SSPR	https://aka.ms/sspr → 2 méthodes → nouveau mot de passe → notification reçue.
T7	Journaux de connexion	entra.microsoft.com → Surveillance → Journaux de connexion → politiques CA visibles dans la colonne « Résultat de la politique CA ».

Checklist de remise client

☐	Action	Vérification	nLPD
☐	Deux comptes break-glass créés (bga1 + bga2, méthodes différentes)	entra.microsoft.com → Utilisateurs	
☐	Groupe `GRP-CA-BreakGlass` créé (bga1 + bga2)	entra.microsoft.com → Groupes	
☐	Security Defaults désactivé	entra.microsoft.com → Propriétés	
☐	Authenticator + FIDO2 + SMS activés	Protection → Méthodes d'auth	art. 8
☐	Passe d'accès temporaire activée (usage unique, 1 h par défaut)	Protection → Méthodes → Passe d'accès temporaire	
☐	Campagne d'inscription active (tous les utilisateurs, sauf break-glass)	Protection → Méthodes → Campagne d'inscription	
☐	Emplacement `Pays-Autorises-[Client]` créé	CA → Emplacements nommés	art. 8
☐	CA-01 MFA : Application (après 7 j de rapport)	CA → Stratégies → CA-01	art. 8
☐	CA-02 Auth héritée : Application directe	CA → Stratégies → CA-02	art. 8
☐	CA-03 Filtrage géo : Application (après 14 j de rapport)	CA → Stratégies → CA-03	art. 8
☐	CA-04 Token Protection : Rapport uniquement (Application après MVC Intune)	CA → Stratégies → CA-04	art. 8
☐	CA-05 Session limitée : Application	CA → Stratégies → CA-05	art. 8
☐	CA-06 Hors horaires : Rapport uniquement	CA → Stratégies → CA-06	art. 8
☐	CA-08 Appareil conforme : Rapport uniquement (Application après MVC Intune)	CA → Stratégies → CA-08	art. 8
☐	SSPR activé pour `GRP-SSPR-Utilisateurs` (2 méthodes)	Protection → Réinit. MDP	art. 8
☐	Test T1 MFA déclenché validé	Navigation privée	
☐	Test T2 Break-glass non bloqué validé	Connexion bga1	
☐	Test T3 Auth héritée bloquée validé	Client IMAP	
☐	Test T6 SSPR fonctionnel validé	https://aka.ms/sspr	

Annexe A : Glossaire

Terme	Définition
AiTM (Adversary-in-the-Middle)	Attaque interceptant la session après un MFA réussi en volant le cookie de session. Token Protection (CA-04) bloque cette attaque. Voir l'annexe AiTM.
Authentication Strength	Fonctionnalité CA P1 définissant le niveau minimal de méthode d'authentification requis. 3 niveaux intégrés : Authentification multifacteur, Authentification multifacteur sans mot de passe, MFA anti-hameçonnage.
Break-glass	Comptes admin d'urgence exclus de toutes les politiques CA. Utilisés uniquement si le tenant est verrouillé. Deux comptes recommandés avec des méthodes différentes. Doivent avoir FIDO2 ou CBA enregistré (MFA des portails admin obligatoire depuis 2025). Noms neutres recommandés en production.
CAE (Continuous Access Evaluation)	Révocation des sessions M365 en temps réel si un changement est détecté (désactivation de compte, IP suspecte).
Credential stuffing	Attaque automatisée testant des millions de paires identifiant/mot de passe volés sur d'autres services.
Contrôles personnalisés / MFA externe	Les « Contrôles personnalisés » CA (MFA tiers) sont remplacés par MFA externe (External MFA). Depuis septembre 2026, il n'est plus possible d'ajouter ou de modifier des contrôles personnalisés ; le retrait complet est prévu début 2027 (source : documentation Microsoft Learn). Non utilisés dans le MVC : à vérifier si le client a un fournisseur MFA tiers.
Emplacement nommé	Zone géographique (pays) ou plage IP définie dans Entra ID, utilisée comme condition dans les politiques CA.
Entra Connect / Cloud Sync	Outil de synchronisation entre l'Active Directory local et Entra ID. Requis en environnement hybride. Microsoft encourage Entra Cloud Sync (agent léger cloud-natif). Pour Entra Connect Sync, la version 2.6.84.0 ou supérieure avec l'authentification basée sur une application est obligatoire avant le 7 avril 2027, sans quoi la synchronisation s'arrête (échéance précédemment annoncée au 30 septembre 2026, avec la version 2.5.79.0, puis repoussée).
FIDO2 / Passkey	Standard cryptographique pour l'authentification sans mot de passe. Résistant au phishing car lié à l'URL de destination.
MFA	Multi-Factor Authentication. Exige deux facteurs : mot de passe + téléphone (ou biométrie).
Mode Rapport uniquement	Les politiques CA sont évaluées mais n'appliquent aucun contrôle. Permet de tester l'impact avant activation.
PFPDT	Préposé fédéral à la protection des données et à la transparence, autorité de contrôle suisse.
SSPR	Self-Service Password Reset. Réinitialisation autonome et auditée du mot de passe sans helpdesk.
TAP (Temporary Access Pass, « Passe d'accès temporaire »)	Code temporaire à usage unique pour enregistrer le premier facteur MFA lors de l'onboarding.
Token Protection	Fonctionnalité CA P1 liant les tokens d'accès à l'appareil émetteur. Bloque le rejeu de tokens volés.

Annexe B : Checklist MVC complète avec références nLPD

Prérequis

☐	Action	Portail / Chemin	nLPD
☐	Deux comptes break-glass créés (bga1 + bga2)	entra.microsoft.com → Utilisateurs	
☐	Groupe `GRP-CA-BreakGlass` créé	entra.microsoft.com → Groupes	
☐	Security Defaults désactivé	entra.microsoft.com → Propriétés → Paramètres de sécurité	

Méthodes d'authentification

☐	Action	Portail / Chemin	nLPD
☐	Authenticator activé, tous les utilisateurs	Protection → Méthodes d'auth → Authenticator	art. 8
☐	FIDO2/Passkeys activé, synchronisé + lié à l'appareil	Protection → Méthodes d'auth → Passkey	art. 8
☐	SMS activé (secours)	Protection → Méthodes d'auth → SMS	
☐	Passe d'accès temporaire activée, usage unique, 1 heure par défaut	Protection → Méthodes d'auth → Passe d'accès temporaire	
☐	Campagne d'inscription active (tous les utilisateurs, sauf break-glass)	Protection → Méthodes d'auth → Campagne d'inscription	
☐	MFA per-user legacy vérifié (tous en Désactivé)	admin.microsoft.com → Utilisateurs actifs → MFA	

Emplacements nommés

☐	Action	Portail / Chemin	nLPD
☐	Emplacement `Pays-Autorises-[Client]` créé (CH + pays voisins)	CA → Emplacements nommés	art. 8
☐	Emplacement `Bureau-[Client]` créé si IP fixe disponible	CA → Emplacements nommés	

Politiques d'accès conditionnel

☐	Action	Portail / Chemin	nLPD
☐	CA-01 MFA tous utilisateurs : Application (après 7 j de rapport)	CA → Stratégies → CA-01	art. 8
☐	CA-02 Blocage auth héritée : Application directe	CA → Stratégies → CA-02	art. 8
☐	CA-03 Filtrage géographique : Application (après 14 j de rapport)	CA → Stratégies → CA-03	art. 8
☐	CA-04 Token Protection : Rapport uniquement (Application après MVC Intune)	CA → Stratégies → CA-04	art. 8
☐	CA-05 Session limitée : Application	CA → Stratégies → CA-05	art. 8
☐	Prérequis CA-05 : SharePoint Admin → accès limité au web actif	admin.sharepoint.com → Stratégies → Partage	art. 8

☐	Action	Portail / Chemin	nLPD
☐	CA-06 Hors horaires : Rapport uniquement	CA → Stratégies → CA-06	art. 8
☐	CA-08 Appareil conforme : Rapport uniquement (Application après MVC Intune)	CA → Stratégies → CA-08	art. 8

SSPR

☐	Action	Portail / Chemin	nLPD
☐	SSPR activé pour `GRP-SSPR-Utilisateurs`	Protection → Réinit. MDP → Propriétés	art. 8
☐	2 méthodes configurées (Authenticator, Téléphone, Email)	Protection → Réinit. MDP → Méthodes	art. 8
☐	Notifications utilisateur + admin activées	Protection → Réinit. MDP → Notifications	art. 8
☐	Écriture différée activée (si environnement hybride)	Protection → Réinit. MDP → Intégration locale	art. 8

Tests et validation

☐	Action	Portail / Chemin	nLPD
☐	T1 MFA déclenché sur compte utilisateur standard	Navigation privée → connexion	
☐	T2 Break-glass non bloqué par CA-01	Connexion bga1 et bga2	
☐	T3 Auth héritée bloquée (CA-02)	Client IMAP ou Outlook ancien	
☐	T5 Session limitée SharePoint (CA-05)	Appareil non géré → SharePoint	
☐	T6 SSPR fonctionnel	https://aka.ms/sspr	
☐	Journaux de connexion, colonnes CA visibles	entra.microsoft.com → Surveillance	

Annexe C : Références nLPD, mesures techniques couvertes

Ce tableau peut être utilisé comme pièce justificative lors d'un audit PFPDT. Référence : **nLPD RS 235.1**, en vigueur depuis le 1er septembre 2023. Délai de notification d'une violation : **« dès que possible »** (pas 72 heures comme dans le RGPD européen). Autorité : **PFPDT** (pas la CNIL). Amende maximale : 250'000 CHF (personne physique).

Article nLPD	Obligation	Mesure technique déployée	Section
art. 8 al. 1	Mesures techniques adaptées au risque : contrôle des accès	MFA obligatoire via CA-01 (Authentication Strength niveau 1)	Partie 3
art. 8 al. 1	Fermer les vecteurs de contournement	Blocage authentification héritée (IMAP, POP3, SMTP) via CA-02	Partie 4
art. 8 al. 1	Réduction de la surface d'attaque géographique	Filtrage géographique : blocage des pays non autorisés via CA-03	Partie 5
art. 8 al. 1	Protection contre le vol de session post-MFA	Token Protection : tokens liés à l'appareil via CA-04	Partie 6
art. 8 al. 1	Contrôle des accès depuis appareils non gérés	Session restreinte SharePoint/OneDrive via CA-05	Partie 7

Article nLPD	Obligation	Mesure technique déployée	Section
art. 8 al. 1	Réduction de la surface d'attaque temporelle	Blocage ou signalement des connexions hors horaires via CA-06	Partie 8
art. 8 al. 1	Contrôle d'accès par état de sécurité de l'appareil	CA-08 Exiger un appareil conforme (Rapport, puis Application après MVC Intune)	Partie 9
art. 8 al. 1	Traçabilité des réinitialisations de mots de passe	SSPR : réinitialisation auditée, 2 méthodes requises	Partie 10
art. 8 al. 1	Authentification forte : résistance au phishing	FIDO2/Passkeys + Authentication Strength	Partie 1
art. 8 al. 1	Continuité d'accès sécurisée	Deux comptes break-glass avec méthodes différentes	§0.2
art. 8 al. 2	Intégrité des sessions : prévention de la compromission	CAE (Continuous Access Evaluation) : révocation en temps réel	Partie 3 (natif)
art. 24	Détection des compromissions de compte	Journaux de connexion Entra ID consultables et blocages CA détectés par le SIEM (règles UTMStack M14 et M3)	Parties 8 et 11 (T7)

Annexe D : Tableau récapitulatif des politiques CA

Politique	Lic.	Cible	Condition	Action
CA-01-MFA-Tous-Utilisateurs	P1	Tous (sauf BG)	Toutes ressources	MFA niveau 1
CA-02-Blocage-Auth-Heritee	P1	Tous	Auth héritée	Bloquer
CA-03-Blocage-Pays-Non-Autorises	P1	Tous	Hors pays autorisés	Bloquer
CA-04-Token-Protection	P1	Pilote Direction	Exchange + SharePoint	Session liée à l'appareil
CA-05-Session-Limitee	P1	Tous	SPO + appareils non gérés	Accès web uniquement
CA-06-Blocage-Hors-Horaires	P1	Tous (sauf BG)	Hors heures ouvrables (via Graph API)	Bloquer (Rapport au départ)
CA-08-Exiger-Appareil-Conforme	P1	Tous (sauf BG)	Toutes ressources	Appareil conforme

INFO CA-04 et CA-08 restent en mode Rapport uniquement jusqu'au déploiement du MVC Intune + Defender. C'est dans le guide Intune + Defender qu'ils passent en Application. CA-06 est créée en mode Rapport ; son passage en Application est une décision du client après revue des journaux. Il n'existe pas de politique CA-07 dans le MVC.

Annexe E : Adaptations sectorielles

Les adaptations ci-dessous s'appliquent en supplément du MVC standard. Le reste du guide reste valide sans modification.

Secteur	Point de rupture	Adaptation recommandée
PME générique	Aucun	MVC tel quel. Aucune adaptation requise.

Secteur	Point de rupture	Adaptation recommandée
Fiduciaire itinérante	Connexions depuis les bureaux de clients (IP variables)	CA-03 : remplacer Bloquer par Exiger MFA. Les connexions hors Suisse sont autorisées après MFA.
Cabinet médical / Avocats	Confidentialité maximale exigée	CA-04 Token Protection : priorité haute, à déployer dès que Intune est actif. CA-01 : Authentication Strength niveau 2 (sans mot de passe) plutôt que niveau 1.
Agence de communication (nomades)	Collaborateurs en télétravail depuis l'étranger	CA-03 : mode MFA plutôt que blocage. Ajouter les pays de télétravail habituels à `Pays-Autorises-[Client]`.
Architecture / Ingénierie	Chantiers en Suisse et pays voisins	Vérifier que CH + DE + FR + IT sont dans `Pays-Autorises-[Client]`. Aucune autre adaptation requise.

Annexe F : Différences POC et production

Point	POC (test)	Production (recommandé)
Comptes break-glass	1 compte admin testé	2 comptes avec méthodes différentes, mots de passe hors ligne
Méthodes MFA	Authenticator + SMS	Authenticator (priorité) + FIDO2 pour Direction et admins
CA-01 mode	Rapport 7 jours puis Application	Application après validation sur un groupe pilote
CA-03 mode	Rapport 14 jours puis Application	Application après revue des journaux de connexion
CA-04 Token Protection	Rapport (Intune non déployé)	Application après déploiement MVC Intune + Defender
SSPR écriture différée	Optionnelle (cloud-only)	Obligatoire en environnement hybride AD
Test break-glass	Manuel lors du déploiement	Trimestriel, documenté dans le registre de sécurité
Alertes connexions suspectes	Vérification manuelle hebdomadaire	Alertes automatisées (SIEM, MDCA ou Sentinel)